

Secure Development Lifecycle Practices

Revision History:

1.0-create 2026-09-23 HK Created

1.0draft 2026-09-29 HK Customer draft+

Introduction

This material is prepared for use in Secure Development Lifecycle Practices and was prepared by Henrik Kramselund, h1k@zencurity.com.

It contains the plan for the course!

These course and exercises are expected to be performed in a training setting with network connected systems. The exercises use a number of tools which can be copied and reused after training. A lot is described about setting up your workstation in the Git repositories.

Overall plan

The overall plan for this course is to outline the idea behind Secure Development Lifecycle Practices.

About the course

- Two days of software security lessons
- Each day is about 6 lessons each 45min with breaks
9:00 - 16:00 with 45min lunch
- Optional open ended exercises lesson at the end – 30 min
- Parts from Software Security course

Depending on the number of attendees there may be exercises during the day.

Note: this is a very large subject. The main goal is to introduce the most important terms, so the attendees can continue on their journey from an overview of this field.

Requirements for Secure Development

A large part of this course is to match requirements for security into the development processes.

Input from ISMS projects

ISO 27001:2022, Annex A

- 8.25 Secure development life cycle
- 8.26 Application security requirements
- 8.27 Secure system architecture and engineering principles
- 8.28 Secure coding
- 8.29 Security testing in development and acceptance
- 8.30 Outsourced development

Secure Development Lifecycle Practices

- 8.31 Separation of development, test and production environments

Subject plans for the two days, some changes may happen:

Day 0 Basic stuff

- Software security in general how does things fail
- History, cases, vulnerabilities, falsehoods and assumptions
- Security principles: least privilege, fail-safe defaults, etc.
- OWASP Top 10, CVE/CWE og "Monster mitigations"
- Security patterns, insecure and secure design
- Policies, coding standards, compiler warnings, git hooks, defensive programming
- Code-Auditing Strategies: static analysis and dynamic analysis
- Security Testing Versus Traditional Software Testing
- Secure Development Lifecycle (SDL, SDLC, SSDL)
- Standards ISO27001/CIS Controls, Application Software Security

Day 1 Advanced subjects and details:

- Authentication: Tokens, MFA, etc.
- Privacy by Design, Secure by Design
- Continuous Vulnerability Management
- Container security
- Third-party dependencies and examples like Log4Shell
- Program Building Blocks and Design Patterns
- Design with Dependencies in Mind, Design for Faults, Design with Promises in Mind
- Tools and pipelines, Continuous Integration - with a few examples
- Building Secure Infrastructures: Separation of development, test and production environments, with examples from Kubernetes
- Enhance and secure runtime environment
- Logging efficiently – Maintenance, Monitoring and Analysis of Audit Logs

Training environments - with Juice Shop as example will be mentioned already on day 0 and used for demos. This system can easily be setup by developers using either docker og Kubernetes.

Time schedule

The above subjects will be put into these lessons: Plan for the day - day 0

- 09:00 - 09:45 – 45min TBD
- 10:00 - 10:45 – 45min TBD
- 11:00 - 11:45 – 45min TBD
- 11:45 - 12:30 – Lunch

Secure Development Lifecycle Practices

- 12:30 - 13:15 – 45min TBD
- 13:30 - 14:15 – 45min TBD
- 14:30 - 15:15 – 45min TBD
- 15:30 - 16:00 – 30min Optional: Exercises, questions

Plan for the day - day 1

- 09:00 - 09:45 – 45min TBD
- 10:00 - 10:45 – 45min TBD
- 11:00 - 11:45 – 45min TBD
- 11:45 - 12:30 – Lunch
- 12:30 - 13:15 – 45min TBD
- 13:30 - 14:15 – 45min TBD
- 14:30 - 15:15 – 45min TBD
- 15:30 - 16:00 – 30min Optional: Exercises, questions